

Lab Answers: Hunting SCATTERED SPIDER Phishing Infrastructure

A small number of phishing-related transactions were intentionally woven into this dataset.

These transactions are not isolated, not labeled, and not grouped together. They are interspersed among legitimate traffic to realistically simulate how eCrime (specifically SCATTERED SPIDER) activity appears in production environments.

Key characteristics of the embedded activity:

- The transactions are allowed, not blocked
- They leverage look-alike domains designed to blend in with trusted SaaS platforms (specifically SurveyMonkey authentication)
- They rely on naming patterns and behavior, not known-bad indicators
- No single transaction is conclusive on its own

The expectation is that students will:

- Reduce noise through grouping and aggregation
- Apply threat intelligence-informed reasoning
- Identify suspicious patterns that only emerge when viewed in context

*SCATTERED SPIDER doesn't rely on malware.
They rely on your users trusting what looks familiar.*

There are several approaches to take. The solution below is just one approach.

Step 1: Reduce the Dataset to Unique Domains

Start by extracting and grouping domains from the URL field.

Shell

```
awk -F', ' '{
  gsub(/^"|"$/, "", $8)
  split($8, a, "/")
  print a[1]
```

```
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr
```

This reduces the dataset from 16,000+ rows to smaller grouped domains, making analysis feasible. With a dataset spanning more than an hour and a single user, further filtering will be needed.

```
@themikewylie → /workspaces/threat-hunting-lab-zia (main) $ awk -F',' '{
  gsub(/^[^"]*"$/, "", $8)
  split($8, a, "/")
  print a[1]
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr
6440 mozilla.cloudflare-dns.com
842 prod.smassets.net
509 www.google.com
381 house-fastly-signed-us-east-1-prod.brightcovecdn.com
298 pagead2.googlesyndication.com
298 akm.live.cnn.us.prd.media.max.com
288 www.youtube.com
224 fly.live.cnn.us.prd.media.max.com
191 lf16-tiktok-web.tiktokcdn-us.com
185 media.cnn.com
180 www.cnn.com
176 rr2---sn-a5m7lnld.googlevideo.com
161 i.ytimg.com
138 fly.amer-free.prd.media.cnn.com
136 metrics.brightcove.com
128 assets.msn.com
125 prod-images.merino.prod.webservices.mozgcp.net
103 ping.chartbeat.net
87 www.surveymonkey.com
87 img-getpocket.cdn.mozilla.net
86 mcs.tiktokw.us
85 googleads.g.doubleclick.net
80 www.googletagmanager.com
78 akm.amer-free.prd.media.cnn.com
75 cdn.uconnectlabs.com
```

The 600+ grouped domains are still a lot to process. There are a few different approaches to narrow this down. One approach is to revise the query to first look for `POST` requests since the hypothesis is phishing / credential harvesting. This approach reduces the results to 112 grouped domains.

```
grep POST ./data/lab_phishing.csv | awk -F',' '{
  gsub(/^[^"]*"$/, "", $8)
  split($8, a, "/")
  print a[1]
}' | sort | uniq -c | sort -nr
```

Performing a thin-tail analysis (looking at the least frequent events), would have highlighted the suspicious domain:

```

@themikewylie → /workspaces/threat-hunting-lab-zia (main) $ grep POST ./data/lab_phishing.csv | awk -F',' '{
  gsub(/~|"/, "", $8)
  split($8, a, "/")
  print a[1]
}' | sort | uniq -c | sort -nr
  4 services.brightline.tv
  4 rr2---sn-a5mlrnek.googlevideo.com
  4 prebid.media.net
  4 krk2.kargo.com
  4 i.clean.gg
  4 htlb.casalemedia.com
  4 hopenbid.pubmatic.com
  4 hb.openwebmp.com
  4 grid-bidder.criteo.com
  4 exchange.postrelease.com
  4 events.brightline.tv
  4 direct.adsrvr.org
  4 busy.any-any.prn.api.discomax.com
  4 aax.amazon-adsystem.com
  3 sync.outbrain.com
  3 rr1---sn-a5mlrnl6.googlevideo.com
  3 navvy.media.net
  3 b1-wndc1.zemanta.com
  3 array810.prod.do.dsp.mp.microsoft.com
  3 api-sr.amplitude.com
  2 www.tiktokw.us
  2 www.nasdaq.com
  2 www.bing.com
  2 usync.ingage.tech
  2 tungsten-service.prod.na.adsqtungsten.a9.amazon.dev
  2 tpsc-uw1.doubleverify.com
  2 smetrics.cnn.com
  2 siteintercept.qualtrics.com
  2 safebrowsing.googleapis.com
  2 privacyportal-eu.onetrust.com
  2 id5-sync.com
  2 help.surveymonkey.com
  2 comcluster.cxense.com
  2 bam.nr-data.net
  2 auth-us.surveymonkey.com
  2 analytics-ipv6.tiktokw.us
  2 17de4c17.akstat.io
  1 www.googletagmanager.com
  1 www.btd-cmh.tq-tungsten.com
  1 wt.dm00.com
  1 webcast.us.tiktok.com
  1 tracking.crazyegg.com
  1 tracking-api.g2.com
  1 token.wmcdp.io
  1 t.pubmatic.com
  1 sr.qualtrics.com
  1 rr5---sn-a5msen7z.googlevideo.com
  1 rr2---sn-a5msen7s.googlevideo.com
  1 prod.us-east-1.cxm-bcn.publisher-services.amazon.dev
  1 pixel.quantserve.com
  1 pixel.alpharank.io
  1 pdx1.sr.qualtrics.com
  1 mpc2-prod-25-is5qnl632q-wl.a.run.app
  1 m.stripe.com
  1 linkedin.sc.omtrdc.net
  1 libraweb.tiktokw.us
  1 js.zi-scripts.com
  1 identity.surveymonkey.com
  1 googleads.g.doubleclick.net
  1 esp.rtbhouse.com
  1 edge.microsoft.com
  1 buy.tinypass.com
  1 auth-us-surveymonkey.com
  1 303-qkm-463.mktosp.com

```

Another approach is to focus on targeted (or Crown Jewel) platforms. The CTI tip in the lab guide suggested eCrime groups masquerade legitimate platforms such as:

- QuickBooks
- AppSheet
- Canva
- SurveyMonkey
- Google Docs
- Zoom

We can write a Bash command like the one below to look for matches to any of the targeted platforms:

```
Shell
awk -F',' '{
    gsub(/^[^"]*"$/, "", $8)
    split($8, a, "/")
    print a[1]
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr | grep -E
'quickbooks|appsheet|canva|surveymonkey|google-docs|zoom'
```

The output provides a manageable list to manually parse:

```
@themikewylie → /workspaces/threat-hunting-lab-zia (main) $ awk -F',' '{
    gsub(/^[^"]*"$/, "", $8)
    split($8, a, "/")
    print a[1]
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr | grep -E 'quickbooks|appsheet|canva|surveymonkey|google-docs|zoom'
87 www.surveymonkey.com
34 ws.zoominfo.com
10 gtm.surveymonkey.com
10 get.surveymonkey.com
7 auth-us.surveymonkey.com
6 us-auth.surveymonkey.com
6 help.surveymonkey.com
6 auth-us-surveymonkey.com
2 surveymonkey.com
2 identity.surveymonkey.com
1 ws-assets.zoominfo.com
1 surveymonkey.chilipiper.com
1 secure.surveymonkey.com
1 auth-us-surveymonkey.com:443
```

If we see a legitimate tool with numerous subdomains, we can exclude the noise by appending doing an inverse grep (`grep -viE ' (^|\.)surveymonkey\.com ($|\.) '`).

```
Shell
awk -F',' '{
    gsub(/^[^"]*"$/, "", $8)
    split($8, a, "/")
    print a[1]
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr | grep -E 'quickbooks|appsheet|canva|surveymonkey|google-docs|zoom'
```

```
} ' ./data/lab_phishing.csv | sort | uniq -c | sort -nr | grep -E  
'quickbooks|appsheet|canva|surveymonkey|google-docs|zoom' | grep  
-viE ' (^|\.)surveymonkey\.com($|\.)'
```

This produces an even smaller result set, highlighting the infrastructure used by the threat actor to masquerade as the legitimate SurveyMonkey authentication subdomain.

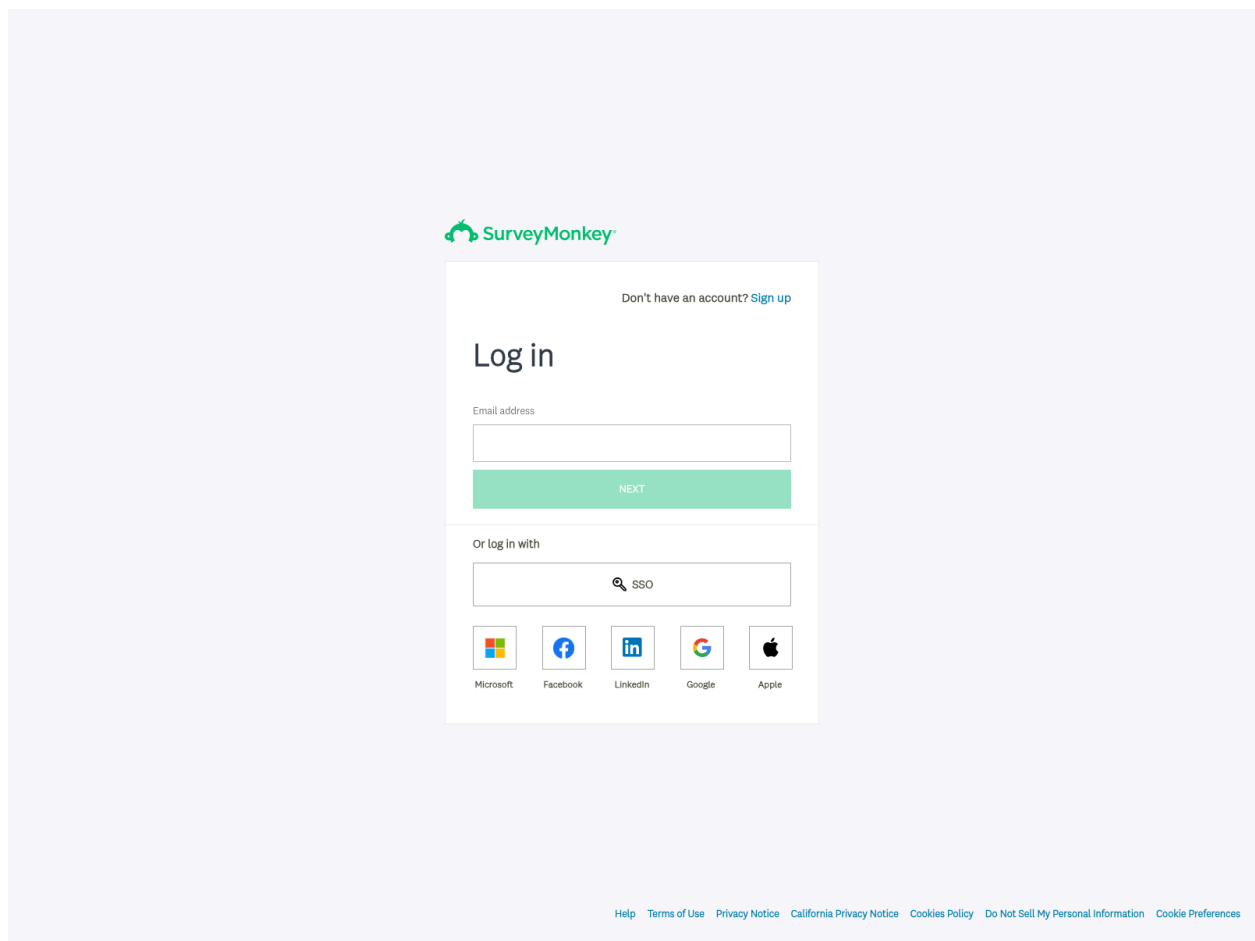
```
geth@kali:~/workspaces/threat-hunting-lab-2ia (main) $ awk -F',' '{
    gsub(/"/,"", $0)
    split($0, a, ",")
    print a[1]
}' ./data/lab_phishing.csv | sort | uniq -c | sort -nr | grep -E 'quickbooks|appsinfo|canva|surveymonkey|google-zoom' | grep -vIE '^(^\.)\.surveymonkey\.com($|\.)'
34 ws.zoominfo.com
1 auth-us-surveymonkey.com
2 surveymonkey.com
1 ws-assets.zoominfo.com
1 surveymonkey.chilipiper.com
1 auth-us-surveymonkey.com:443
```

If we zoom back out and analyze the raw telemetry to/from the domain, we can see several `POST` requests, indicating potential successful credential harvesting.

```

C:\Users\user\Documents\workspace\threat-hunting-lab-zia (x64) % grep auth-surveymonkey /gdata/lab_phishing.csv | grep MSF
7158 January 30, 2026 12:46:11 PM PST, karenabc,scansec.net, Yes,auth-surveymonkey.com/js/php/main.php?allowed=1,2,3,4,5,6,7,8,9,10,11,12,13,14,15,16,17,18,19,20,21,22,23,24,25,26,27,28,29,30,31,32,33,34,35,36,37,38,39,40,41,42,43,44,45,46,47,48,49,50,51,52,53,54,55,56,57,58,59,60,61,62,63,64,65,66,67,68,69,70,71,72,73,74,75,76,77,78,79,80,81,82,83,84,85,86,87,88,89,90,91,92,93,94,95,96,97,98,99,100,101,102,103,104,105,106,107,108,109,110,111,112,113,114,115,116,117,118,119,120,121,122,123,124,125,126,127,128,129,130,131,132,133,134,135,136,137,138,139,140,141,142,143,144,145,146,147,148,149,150,151,152,153,154,155,156,157,158,159,160,161,162,163,164,165,166,167,168,169,170,171,172,173,174,175,176,177,178,179,180,181,182,183,184,185,186,187,188,189,190,191,192,193,194,195,196,197,198,199,200,201,202,203,204,205,206,207,208,209,210,211,212,213,214,215,216,217,218,219,220,221,222,223,224,225,226,227,228,229,230,231,232,233,234,235,236,237,238,239,240,241,242,243,244,245,246,247,248,249,250,251,252,253,254,255,256,257,258,259,260,261,262,263,264,265,266,267,268,269,270,271,272,273,274,275,276,277,278,279,280,281,282,283,284,285,286,287,288,289,290,291,292,293,294,295,296,297,298,299,300,301,302,303,304,305,306,307,308,309,310,311,312,313,314,315,316,317,318,319,320,321,322,323,324,325,326,327,328,329,330,331,332,333,334,335,336,337,338,339,340,341,342,343,344,345,346,347,348,349,350,351,352,353,354,355,356,357,358,359,360,361,362,363,364,365,366,367,368,369,370,371,372,373,374,375,376,377,378,379,380,381,382,383,384,385,386,387,388,389,390,391,392,393,394,395,396,397,398,399,400,401,402,403,404,405,406,407,408,409,410,411,412,413,414,415,416,417,418,419,420,421,422,423,424,425,426,427,428,429,430,431,432,433,434,435,436,437,438,439,440,441,442,443,444,445,446,447,448,449,450,451,452,453,454,455,456,457,458,459,460,461,462,463,464,465,466,467,468,469,470,471,472,473,474,475,476,477,478,479,480,481,482,483,484,485,486,487,488,489,490,491,492,493,494,495,496,497,498,499,500,501,502,503,504,505,506,507,508,509,510,511,512,513,514,515,516,517,518,519,520,521,522,523,524,525,526,527,528,529,530,531,532,533,534,535,536,537,538,539,540,541,542,543,544,545,546,547,548,549,550,551,552,553,554,555,556,557,558,559,560,561,562,563,564,565,566,567,568,569,570,571,572,573,574,575,576,577,578,579,580,581,582,583,584,585,586,587,588,589,590,591,592,593,594,595,596,597,598,599,600,601,602,603,604,605,606,607,608,609,610,611,612,613,614,615,616,617,618,619,620,621,622,623,624,625,626,627,628,629,630,631,632,633,634,635,636,637,638,639,640,641,642,643,644,645,646,647,648,649,650,651,652,653,654,655,656,657,658,659,660,661,662,663,664,665,666,667,668,669,670,671,672,673,674,675,676,677,678,679,680,681,682,683,684,685,686,687,688,689,690,691,692,693,694,695,696,697,698,699,700,701,702,703,704,705,706,707,708,709,710,711,712,713,714,715,716,717,718,719,720,721,722,723,724,725,726,727,728,729,730,731,732,733,734,735,736,737,738,739,740,741,742,743,744,745,746,747,748,749,750,751,752,753,754,755,756,757,758,759,760,761,762,763,764,765,766,767,768,769,770,771,772,773,774,775,776,777,778,779,780,781,782,783,784,785,786,787,788,789,790,791,792,793,794,795,796,797,798,799,800,801,802,803,804,805,806,807,808,809,810,811,812,813,814,815,816,817,818,819,820,821,822,823,824,825,826,827,828,829,830,831,832,833,834,835,836,837,838,839,840,841,842,843,844,845,846,847,848,849,850,851,852,853,854,855,856,857,858,859,860,861,862,863,864,865,866,867,868,869,870,871,872,873,874,875,876,877,878,879,880,881,882,883,884,885,886,887,888,889,890,891,892,893,894,895,896,897,898,899,900,901,902,903,904,905,906,907,908,909,910,911,912,913,914,915,916,917,918,919,920,921,922,923,924,925,926,927,928,929,930,931,932,933,934,935,936,937,938,939,940,941,942,943,944,945,946,947,948,949,950,951,952,953,954,955,956,957,958,959,960,961,962,963,964,965,966,967,968,969,970,971,972,973,974,975,976,977,978,979,980,981,982,983,984,985,986,987,988,989,990,991,992,993,994,995,996,997,998,999,1000,1001,1002,1003,1004,1005,1006,1007,1008,1009,1010,1011,1012,1013,1014,1015,1016,1017,1018,1019,1020,1021,1022,102
```

Never visit potentially malicious URLs on a production machine. The below screenshot is what the malicious phishing URL looked like at the time of the finding, confirming our suspicions of potential credential harvesting.



This attack and the domain in question show several characteristics consistent with the SCATTERED SPIDER eCrime group:

- **AS63949 Use:** The group frequently uses this known Autonomous System Number (ASN) to register targeted phishing domains.
- **Domain Name Pattern:** The domains follow a pattern of using known login or SSO (Single Sign-On) related keywords followed by the target company's name. A typical example is `auth-{company_name}.tld`.
- **Phishing Content:** The content used is the group's familiar targeted SSO phishing material.

It is important to contrast the legitimate SurveyMonkey SSO domain, which is `auth-us.surveymonkey[.]com`, with the malicious, targeted phishing domain registered and exploited in this attack, which is `auth-us-surveymonkey[.]com`.